UDA 10 · LA SICUREZZA E LA PROTEZIONE DEI DATI

L'autenticazione dell'utente

Password, passphrase, codici che durano trenta secondi: come fa un sistema a sapere che sei proprio tu?

PER COMINCIARE

Sii sincero: quante password diverse usi davvero?

SONDAGGIO

- **A** Una sola, per tutto
- **B** Due o tre, a rotazione
- **C** Una diversa per ogni account importante
- **D** Le genera e le ricorda un gestore di password

TRE PAROLE DIVERSE

Chi sei, dimostralo, che cosa puoi fare

1

Identificazione

Dichiari chi sei.

Il nome utente: `m.rossi`

2

Autenticazione

Lo **dimostri**.

Password, codice, impronta.

3

Autorizzazione

Il sistema decide che cosa puoi fare.

Leggere i voti sì, cambiarli no.

> Nel registro elettronico tu e il docente vi autenticate allo stesso modo, ma siete **autorizzati** a fare cose diverse.

I FATTORI DI AUTENTICAZIONE

Tre modi per dimostrare chi sei

Tocca le carte: per ognuna, trova almeno due esempi prima di girarla.

Password, **passphrase**, **PIN**, la risposta a una domanda di sicurezza.

Si può dimenticare o farsi rubare con un inganno.

Smartphone con l'app, la carta d'identità elettronica, una chiavetta di sicurezza.

Si può perdere, ma serve averlo in mano.

Impronta digitale, **volto**, iride, voce.

Comoda, ma non si può cambiare come una password.

QUIZ A TRABOCCHETTO

Quale di queste è una vera autenticazione a due fattori?

QUIZ

A Password + domanda di sicurezza

B Password + codice dall'app sul telefono

C Due password diverse, una dopo l'altra

D PIN + data di nascita

UNA STORIA VERA

La prima password… e il primo furto

1961

MIT, Stati Uniti

Fernando Corbató e il suo gruppo creano CTSS, un computer usato a turno da molti utenti. Per separare file e tempo di calcolo di ciascuno introducono la **password**.

1962

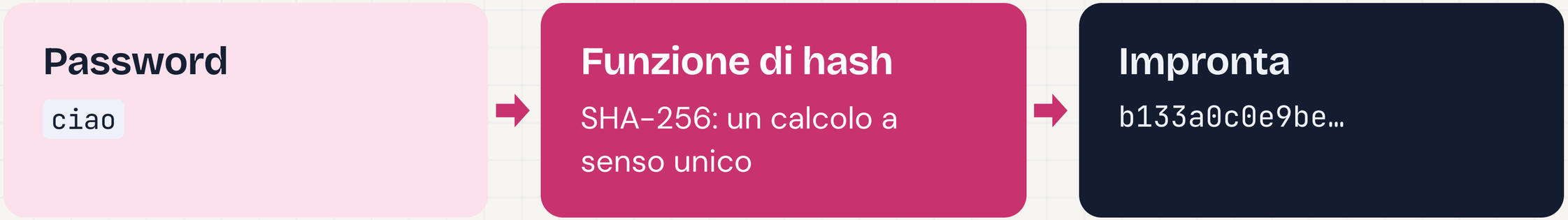
Il primo furto

Il ricercatore Allan Scherr voleva più ore di calcolo. Fece **stampare il file con tutte le password**, che erano salvate in chiaro.

La lezione vale ancora oggi: un sistema non dovrebbe **mai** conservare le password in chiaro.

SOTTO IL COFANO

Il sito conserva l'impronta, non la password



- Dalla stessa password esce **sempre** la stessa impronta.
- Basta cambiare una lettera e l'impronta cambia del tutto: `Ciao` → `25c73520e69f…`
- Dall'impronta **non** si torna indietro alla password.

METTITI ALLA PROVA

Un sito fatto bene come conserva la tua password?

QUIZ

- **A** In chiaro, in un database ben protetto
- **B** Cifrata con una chiave segreta del sito
- **C** Come impronta (hash) con un valore casuale
- **D** Non la conserva: te la chiede ogni volta via email

AL COMPUTER · 15 minuti

L'impronta delle password

1. Apri **gchq.github.io/CyberChef** e trascina l'operazione **SHA2** in Recipe (Size: 256).
2. Scrivi in Input `ciao`, poi `Ciao`, poi `ciao!`: annota i primi 8 caratteri di ogni impronta.
3. Calcola l'impronta di `password` e cercala con un motore di ricerca: che cosa trovi?
4. Scrivi tutto in Writer con una frase di spiegazione. Salva come **impronte.odt**.

Controllo: `ciao` dà un'impronta che inizia con **b133a0c0**, `Ciao` con **25c73520**. L'impronta di `password` inizia con **5e884898** e compare in moltissime pagine: le password comuni sono già "schedate".

COME SI ATTACCA UNA PASSWORD

Forza bruta: provarle tutte

combinazioni possibili

$$\text{simboli}^{\text{lunghezza}}$$

Password	Combinazioni
PIN di 4 cifre	$10^4 = 10\,000$
4 lettere minuscole	$26^4 = 456\,976$
8 lettere minuscole	$26^8 \approx 209$ miliardi

Prima ancora, l'attaccante prova le parole del **dizionario** e le password più usate.



AL COMPUTER · 20 minuti

Quanto resiste la tua password?

1. In Calc, intestazioni da A1 a E1: **Tipo**, **Simboli**, **Lunghezza**, **Combinazioni**, **Anni**.
2. Righe: PIN (10; 4), 8 minuscole (26; 8), 8 lettere e cifre (62; 8), 12 lettere e cifre (62; 12), 6 parole da un elenco di 7776 (7776; 6).
3. In D2 `=POTENZA(B2;C2)`. In E2 `=D2/10000000000/31536000`. Trascina in giù.
4. Aggiungi un grafico a barre degli anni. Salva come **forza-bruta.ods**.

Controllo: 8 minuscole cadono in circa **21 secondi**; 12 lettere e cifre resistono più di **10 000 anni**; 6 parole a caso circa **700 000 anni**.

PASSWORD E PASSPHRASE

Una frase lunga batte una parola complicata

Password complicata

`Tr0ub4dor&3`

Corta, difficile da ricordare, con sostituzioni (o → 0, a → 4) che i programmi di attacco conoscono benissimo.

Passphrase

`falco-ombrello-gelato-marte-sei`

Parole **scelte a caso**, non una frase famosa. Lunga, facile da ricordare, facile da digitare.

> Le parole vanno estratte davvero a caso, per esempio con i **dadi**. "Nel mezzo del cammin di nostra vita" è lunga, ma è in tutti i dizionari di attacco.

QUIZ

Quale resiste più a lungo a un attacco?

QUIZ

A `Giulia2010!`

B `X7#q!z`

C `Password123456`

D `lampone-treno-nuvola-sette-faro`

ONE-TIME PASSWORD

Un codice che vale una volta sola

Nell'app di autenticazione e nel server c'è la **stessa chiave segreta**, scambiata una volta sola con un codice QR. Ogni 30 secondi entrambi calcolano:

codice TOTP di 6 cifre

```
chiave segreta + ora attuale
```

Il codice arriva anche per **SMS**: comodo, ma meno sicuro, perché il numero si può dirottare.

SPID e CIE

Con SPID di livello 2 servono password **e** un codice OTP o una conferma sull'app. La CIE usa la carta (che hai) e il PIN (che sai).

> Un codice OTP **non si detta a nessuno**: né all'amico, né a chi al telefono dice di essere la banca o l'assistenza.

PUZZLE

Accesso con verifica in due passaggi: metti in ordine

1. Il server ti chiede il codice a 6 cifre
2. Scrivi nome utente e password
3. Il server calcola il codice con la stessa chiave e la stessa ora
4. I due codici coincidono: puoi entrare
5. Apri l'app di autenticazione e leggi il codice
6. Il server confronta l'impronta della password con quella salvata

AL COMPUTER · 15 minuti

Due computer, lo stesso codice

1. In coppia: ognuno apre **CyberChef** e trascina l'operazione **Generate TOTP** in Recipe.
2. Tutti e due scrivete in Input la stessa chiave di prova, per esempio `NOVAULA1D2026`.
3. Premete **BAKE!** insieme e confrontate la Password a 6 cifre.
4. Aspettate 30 secondi e ripremete. Poi uno dei due cambia una lettera della chiave.
5. Annota i risultati in **totp.txt**.

Controllo: con la stessa chiave nello stesso momento esce lo **stesso codice**, anche senza collegarsi tra loro. Dopo 30 secondi il codice cambia; con una chiave diversa esce un codice diverso.

MENTI CHE CI HANNO PRECEDUTO

La fine delle password?

> **Non c'è dubbio che, col tempo, le persone si affideranno sempre meno alle password.**

Bill Gates, cofondatore di Microsoft, RSA Conference, San Francisco, 2004



SFIDA FINALE

Apri il lucchetto con quello che hai imparato



- 1ª cifra: quanti sono i tipi di fattori di autenticazione
- 2ª cifra: quante cifre ha di solito un codice OTP
- 3ª e 4ª cifra: per quanti secondi vale un codice TOTP

codice

BIGLIETTO D'USCITA

Completa prima di uscire

Dimostrare di essere chi dici di essere si chiama _____.

Lo smartphone con l'app è un fattore di tipo "qualcosa che _____".

Un sito serio conserva l'_____ della password, non la password.

Un PIN di 4 cifre ha _____ combinazioni.

⏱ 3:00

RIEPILOGO

Cosa portiamo a casa

- Identificazione, autenticazione, autorizzazione
- Tre fattori: sai, hai, sei
- I siti salvano l'impronta, non la password
- Lunghezza batte complessità: meglio una passphrase
- OTP: stessa chiave + stessa ora = stesso codice
- Il futuro: passkey e chiavi asimmetriche

Hai una domanda su una slide? Usa il pulsante **? Domande** in basso: la vedrà il docente e tutta la classe.